

API Security Risk Analysis Report

Aim: API Security Assessment of a Public Demo API

Target API: JSONPlaceholder (jsonplaceholder.typicode.com)

Reported by: N. Smili

Overview:

1. Identify insecure API endpoints
2. Analyze authentication and authorization issues
3. Detect public data exposure risks
4. Test API behavior using Postman
5. Review missing security protections
6. Document API security findings

API Endpoints Tested:

1. GET /posts
2. GET /users/1
3. Authorization Header Testing
4. Token Validation Testing
5. Public Data Exposure Testing

Authorization Issues:

1. User data accessible publicly
2. Direct endpoint access allowed
3. No access restriction implemented
4. Role-based access control missing
5. Sensitive data exposure risk exists
6. Improper authorization observed

Rate Limiting & Validation:

1. Multiple requests accepted continuously
2. No visible rate limiting detected
3. Input validation controls limited
4. API accepts manipulated requests
5. Traffic abuse protection missing
6. Request filtering not implemented

Security Impact:

1. Unauthorized users may access API data
2. Sensitive information exposure possible
3. Attackers may misuse API endpoints
4. Increased risk of API abuse
5. Business data protection weakened
6. Privacy and compliance risks may occur

Conclusion:

API analysis found security issues in authentication, access, and data exposure. Stronger security controls are needed to protect data.

Tools Used:

1. Postman
2. Browser DevTools
3. JSONPlaceholder Public API
4. Google Docs / MS Word

Authentication Analysis:

1. API accessible without login
2. No API key required
3. No JWT validation observed
4. Invalid bearer token accepted
5. Authentication protection missing
6. Unauthorized access possible

Data Exposure Risks:

1. Public API responses visible
2. User information exposed openly
3. Data accessible without verification
4. Endpoint enumeration possible
5. Excessive data exposure risk present
6. API responses lack restriction

Risk Classification:

HIGH RISK

1. Missing Authentication
2. Improper Authorization

MEDIUM RISK

1. Public Data Exposure
2. Invalid Token Acceptance
3. Missing Access Control

LOW RISK

1. Missing Rate Limiting
2. Weak Input Validation

Remediation Steps:

1. Implement JWT/API key authentication
2. Enforce proper token validation
3. Apply role-based access control (RBAC)
4. Restrict public endpoint access
5. Add API rate limiting
6. Validate and sanitize user inputs
7. Return 401 Unauthorized for invalid requests
8. Monitor suspicious API activity